

Ministério Público Federal
Secretaria Geral
Secretaria de Tecnologia da Informação e Comunicação

Orientação Técnica

Nº 17

Privacidade desde o projeto

Documento de referência para o desenvolvimento de software no Ministério Público Federal



Secretaria Geral
Secretaria de Tecnologia da Informação e Comunicação
Gabinete da Secretaria de Tecnologia da Informação e Comunicação

Brasília – DF
11/2022

Elaboração

Paulo Henrique Correa de Moura – SG/STIC

Colaboração

Darlan Airton Dias – SG/STIC
Gustavo Fonseca Goncalves de Almeida
Luís Augusto Vieira Ribeiro
Priscilla Souza Ramos Alves
Nara Lúcia Iurk Zuchelo Ramos

Recorrências

Luís Augusto Vieira Ribeiro
Priscilla Souza Ramos Alves
3105-5959

Versão 1.0

11/2022

Sumário

1. INTRODUÇÃO	4
2. OBJETIVO	4
3. PREMISSAS	4
4. ORIENTAÇÕES	5
4.1. AVISO PRELIMINAR	5
4.2. PRIVACIDADE DESDE O PROJETO	6
4.2.1. O CONCEITO DE PRIVACIDADE DESDE O PROJETO	6
4.2.2. PRIVACIDADE NA LEGISLAÇÃO	6
4.2.3. OS 7 PRINCÍPIOS FUNDAMENTAIS DE PRIVACIDADE DESDE O PROJETO	8
4.3. REQUISITOS DE PRIVACIDADE DOS SISTEMAS	12
4.4. OBJETIVOS DE PRIVACIDADE E SEGURANÇA	13
4.5. PROJETANDO PRIVACIDADE	15
4.6. ESTRATÉGIAS DE PROJETO DE PRIVACIDADE	17
4.7. PADRÕES DE PROJETO DE PRIVACIDADE	26
4.8. CATÁLOGOS DE PADRÕES DE PROJETO	27
4.9. TECNOLOGIAS DE AUMENTO DA PRIVACIDADE (TAPs)	28
4.9.1. CLASSIFICAÇÃO DAS TAPs	28
4.9.2. CATÁLOGO DE TECNOLOGIAS DE AUMENTO DE PRIVACIDADE (TAPs)	29
4.10. CONCLUSÕES	31
5. CONSIDERAÇÕES FINAIS DA ORIENTAÇÃO TÉCNICA	33
6. REFERÊNCIAS BIBLIOGRÁFICAS POR TEMA	34

1. INTRODUÇÃO

A Secretaria de Tecnologia da Informação e Comunicação vem, neste documento, estabelecer um compilado estruturado de normas e boas práticas nacionais e internacionais a respeito do desenvolvimento de produtos considerando a privacidade desde o projeto, às vistas da Lei Geral de Proteção de Dados (LGPD - 13.709/2018).

A LGPD tem como principal objetivo proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural. Também tem como foco a criação de um cenário de segurança jurídica, com a padronização de regulamentos e práticas para promover a proteção aos dados pessoais de todo cidadão que esteja no Brasil, de acordo com os parâmetros internacionais existentes.

A lei define o que são dados pessoais e explica que alguns deles estão sujeitos a cuidados ainda mais específicos, como os dados pessoais sensíveis e dados pessoais sobre crianças e adolescentes. Esclarece ainda que todos os dados tratados, tanto no meio físico quanto no digital, estão sujeitos à regulação. Além disso, a LGPD estabelece que não importa se a sede de uma organização ou o centro de dados dela estão localizados no Brasil ou no exterior: se há o processamento de informações sobre pessoas, brasileiras ou não, que estão no território nacional, a LGPD deve ser observada. A lei autoriza também o compartilhamento de dados pessoais com organismos internacionais e com outros países, desde que observados os requisitos nela estabelecidos.

Este documento detalha orientações a serem seguidas por todos as equipes de desenvolvimento de produtos da Secretaria de Tecnologia da Informação e Comunicação (STIC) nas unidades do MPF.

2. OBJETIVO

Esse documento tem como objetivo ser um guia de referência para o desenvolvimento de produtos no Ministério Público Federal, sejam eles softwares, hardwares, serviços, processos de trabalho, práticas, tecnologias ou infraestrutura, levando em consideração a privacidade desde o projeto.

3. PREMISSAS

A Secretaria de Tecnologia da Informação e Comunicação do MPF registra que:

- O presente documento é um guia para o desenvolvimento de produtos que considera desde o projeto a privacidade dos dados;
- Este documento será amplamente divulgado e utilizado para as soluções de tecnologia da informação e comunicação;

- As sugestões de melhoria e correções deste documento serão analisadas e repassadas os responsáveis pelas solicitações de mudanças.

4. ORIENTAÇÕES

4.1. AVISO PRELIMINAR

O presente documento é um compilado estruturado de normas e boas práticas nacionais e internacionais com o objetivo de ser um documento de referência para o desenvolvimento de produtos no Ministério Público Federal, sejam eles softwares, hardwares, serviços, processos de trabalho, práticas, tecnologias ou infraestrutura, levando em consideração a privacidade desde o projeto.

A maioria das referências foi traduzida de forma livre, com propósitos informativos e não comerciais e com o objetivo de organizar o conhecimento sobre o assunto e de ampliar o acesso a ele no âmbito do MPF.

Não obstante o presente documento não atender requisitos científicos e acadêmicos, justamente por não ser essa a sua destinação, todas as referências são apresentadas no decorrer do texto e agrupadas por tema ao final deste documento.

Ao assim proceder, a Secretaria de Tecnologia da Informação e Comunicação do MPF registra que:

- 1) não representa, tampouco se manifesta em nome de nenhuma das instituições ou órgãos de governo aqui citados;
- 2) não é coautora de nenhuma das publicações abordadas;
- 3) não assume nenhuma responsabilidade administrativa, técnica ou jurídica pelo uso ou pela interpretação inadequados, fragmentados ou parciais do presente documento; e
- 4) caso o leitor deseje se certificar de que atende integralmente os requisitos das publicações aqui citadas, sugerimos buscar suas versões originais, em sua maioria, na língua inglesa, consultando diretamente as fontes oficiais de informação ofertadas pelas referidas instituições, todas constantes nas referências bibliográficas ao final.

4.2. PRIVACIDADE DESDE O PROJETO

4.2.1. O CONCEITO DE PRIVACIDADE DESDE O PROJETO

Durante o desenvolvimento de sistemas, a privacidade é muitas vezes uma reflexão tardia. As proteções de privacidade são uma implementação posterior, adicionada a um aplicativo, programa ou site apenas para cumprir requisitos legais específicos ou para satisfazer as preocupações do usuário.

Entretanto, a ideia de proteção de dados desde a concepção, ou desde o projeto, existe há mais de 20 anos e muitos trabalhos foram realizados nesta área sob o termo “Privacy by Design” que doravante, para o escopo do presente documento, será denominada – em livre tradução – Privacidade desde o Projeto, ou será referida pela sigla PdP.

Este conceito foi desenvolvido por Anne Cavoukian, então Comissária de Proteção de Dados de Ontário, nos anos 90 e apresentado na 31ª Conferência Internacional de Comissários de Proteção e Privacidade de Dados em 2009 com o título “Privacy by design: the definitive workshop. A foreword by Ann Cavoukian, Ph.D.”.

A privacidade desde o projeto foi aceita internacionalmente, como componente fundamental da proteção da privacidade, na 32ª Conferência Internacional de Comissários de Proteção de Dados e Privacidade, realizada em Jerusalém em 2010, com a adoção da “Resolution on Privacy by Design”.

Por meio dessa resolução, foi reconhecida a importância de incorporar os princípios da privacidade nos processos de concepção, funcionamento e gestão dos sistemas organizacionais, de forma a atingir um quadro de proteção integral em matéria de proteção de dados.

Referida resolução também encorajou a adoção dos **7 Princípios Fundamentais da Privacidade desde o projeto**, conforme definidos por Ann Cavoukian, e convidou as Autoridades de Proteção de Dados a trabalhar ativamente com o fim de promover a inclusão da privacidade desde o projeto nas políticas e legislações sobre proteção de dados em seus respectivos Estados.

4.2.2. PRIVACIDADE NA LEGISLAÇÃO

Privacidade desde o Projeto na GDPR

O [Regulamento Geral de Proteção de Dados da União Europeia \(UE\) 2016/679 –GDPR](#), na sigla original em inglês – doravante referido apenas pela sigla original neste documento, em seu artigo 25 e sob o título “Proteção de dados desde o projeto e por padrão” (em livre tradução) incorpora a prática de considerar os requisitos de privacidade desde as primeiras fases do projeto de produtos e serviços em regulamentações de proteção de dados.

Assim, a privacidade assume a característica de requisito legal, a fim de integrar as garantias de proteção dos direitos e liberdades dos cidadãos, no que diz respeito aos seus dados pessoais, desde as fases iniciais de desenvolvimento de sistemas e produtos.

Privacidade desde o Projeto e a LGPD

No Brasil, a Lei 13.709/18, Lei Geral de Proteção de Dados, doravante referida neste documento apenas como LGPD, é o instrumento jurídico que regulamenta, dentre outras coisas, a privacidade de dados pessoais.

A Privacidade desde o Projeto não é nominal e especificamente mencionada na LGPD e também não configura, por si só, um requisito de conformidade. Todavia, ela facilita a adequação à lei, em especial, ao artigo 46:

“Art. 46. Os agentes de tratamento devem **adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais** de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

(...)

§ 2º As medidas de que trata o caput deste artigo deverão ser observadas desde a fase de concepção do produto ou do serviço até a sua execução.”
(sem grifos no original)

Ao se adotar a Privacidade desde o Projeto, o objetivo é especificamente a proteção integral dos dados pessoais desde a concepção do projeto, como determina o artigo 46 da LGPD.

Ainda, constitui importante ferramenta para reduzir custos de conformidade com a lei. Ela permite iniciar um projeto de um produto de maneira já aderente à LGPD, reduzindo sobremaneira o risco de multas e prejuízos decorrentes de incidentes de privacidade.

Privacidade desde o projeto tem como foco a gestão de risco e responsabilidade para estabelecer estratégias que incorporem proteção de privacidade ao longo do ciclo de vida de um produto (seja um software, hardware, serviço, processo de trabalho, prática, tecnologia ou infraestrutura).

Por ciclo de vida de um produto entendemos todas as etapas pelas quais ele passa, desde o desenvolvimento do conceito até a sua remoção, passando pelas etapas de desenvolvimento, produção, operação, manutenção e retirada.

Além disso, necessário levar em consideração não apenas a aplicação de medidas de proteção da privacidade nas fases iniciais do projeto, mas também considerar todos os processos de negócios e práticas que processam os dados associados, alcançando assim uma verdadeira governança da gestão de dados pessoais da instituição.

Ao fim e ao cabo, o objetivo é garantir que a proteção de dados esteja presente desde os estágios iniciais de concepção e não seja apenas uma camada adicionada a um produto.

A privacidade deve ser uma parte integrante da natureza do referido produto.

4.2.3. OS 7 PRINCÍPIOS FUNDAMENTAIS DE PRIVACIDADE DESDE O PROJETO

A privacidade desde o projeto baseia-se na concepção de privacidade como o modus operandi padrão dentro dos modelos de negócios das organizações, estendendo-se aos sistemas de tecnologia da informação que suportam o processamento de dados, processos e práticas de negócios relacionados e o projeto físico e lógico dos canais de comunicação utilizados.

A privacidade pode ser garantida colocando-se em prática os sete princípios fundamentais definidos por Ann Cavoukian:

1. Proativo, não reativo; Preventivo, não corretivo.

PdP envolve antecipar eventos que afetam a privacidade antes que eles ocorram.

Qualquer produto que utilize dados pessoais deve ser concebido e desenhado desde o início, identificando os possíveis riscos aos direitos e liberdades dos titulares dos dados e minimizando-os antes que possam causar danos reais.

A política de PdP é caracterizada pela adoção de medidas pró-ativas que antecipam ameaças, identificam fragilidades nos produtos para neutralizar ou minimizar os riscos, em vez de aplicar medidas corretivas para resolver os incidentes de segurança uma vez ocorridos.

Ou seja, a PdP evita “a política de retificação” e antecipa a materialização do risco.

Incorporar este princípio requer:

- Um compromisso claro da organização que deve ser promovido desde os níveis mais altos da Administração.
- Desenvolver uma cultura de comprometimento e melhoria contínua de todos os colaboradores, pois uma política não significa nada até e a menos que se traduza em ações concretas e movidas a resultados.
- Definir e atribuir responsabilidades concretas para que cada membro da organização esteja claramente ciente de suas tarefas no que diz respeito à privacidade.
- Desenvolver métodos sistemáticos baseados em indicadores para a detecção precoce de processos e práticas deficientes na garantia da privacidade.

2. Privacidade como configuração padrão

A PdP busca estabelecer que a privacidade seja sempre a configuração padrão em qualquer sistema ou prática de negócio, não sendo necessária qualquer configuração por parte do usuário.

É dizer que o usuário não precisa adotar qualquer ação para uma configuração mais restritiva de privacidade, essas configurações já devem vir embutidas de forma padrão no produto.

Caso o usuário não modifique a configuração, sua privacidade está garantida e deve permanecer intacta.

A aplicação prática deste princípio materializa-se na minimização dos dados ao longo das etapas de processamento: compilação, utilização, retenção e distribuição.

Para atender a esse princípio é necessário:

- Tornar os critérios de coleta de dados os mais restritos possível.
- Limitar o uso de dados pessoais aos propósitos para os quais foram coletados e garantir que haja uma base legal para o processamento.
- Tornar os propósitos da coleta de dados específicos, claros, limitados e relevantes às circunstâncias;
- Restringir o acesso aos dados pessoais às partes envolvidas no tratamento de acordo com o **princípio da “necessidade de saber”** e de acordo com a função de criação de perfis de acesso diferenciados.
- Definir prazos estritos de retenção (tabelas de temporalidade) e estabelecer mecanismos operacionais que garantam o cumprimento.
- Criar barreiras tecnológicas e procedimentais para a vinculação não autorizada de fontes independentes de dados.

3. Privacidade incorporada ao projeto

Este princípio orienta a conceber a privacidade já incorporada ao projeto e à arquitetura dos sistemas de TI e práticas de negócio. A privacidade, a partir de agora, deve ser entendida como sendo da essência do sistema.

Não é uma camada ou um módulo adicional que é aplicado ou conectado a uma entidade pré-existente. Ao contrário, deve ser integrada ao grupo de requisitos não funcionais desde os estágios iniciais de desenvolvimento.

Para garantir que a privacidade seja considerada nos estágios iniciais de desenvolvimento, devemos:

- Considerá-la como um requisito essencial dentro do ciclo de vida de sistemas e serviços, bem como na concepção de processos organizacionais.
- Realizar uma análise de risco dos direitos e liberdades das pessoas e, quando aplicável, realizar avaliações de impacto na proteção de dados, como parte integrante de qualquer nova iniciativa de processamento.
- Documentar todas as decisões que são adotadas dentro da organização a partir de uma perspectiva de “pensamento em privacidade”.

- Adotar uma abordagem sistêmica e considerar contextos mais amplos do que apenas os relacionados ao processo de desenvolvimento.
- Adotar uma abordagem integrativa, consultando todos os envolvidos e partes interessadas.
- Adotar uma abordagem criativa, considerando que algumas vezes será necessário se reinventar para adotar práticas realmente aderentes aos princípios de PdP.

4. Funcionalidade total: soma positiva, não soma zero

A metodologia de PdP procura evitar a existência de falsos dilemas, tais como privacidade *versus* usabilidade, privacidade *versus* funcionalidade, privacidade *versus* benefício para o negócio e até mesmo privacidade *versus* segurança.

A ideia é fazer uma composição de todos os interesses e objetivos legítimos da organização, não somente os que tem relação com a privacidade. Em resumo, é buscar uma abordagem *ganha-ganha*.

Para isso, desde os primeiros estágios de desenvolvimento do conceito de produtos, devemos:

- Compreender que podem coexistir interesses diferentes e legítimos: os da organização e os dos usuários aos quais ela presta serviços, e que é necessário identificá-los, avaliá-los e equilibrá-los de acordo.
- Incorporar a privacidade em produtos em que isso prejudique sua funcionalidade total.
- Documentar todos os interesses e objetivos e buscar soluções que permitam a multifuncionalidade, sem que seja preciso abrir mão de um ou outro objetivo.
- Ao verificar que as soluções propostas ameaçam a privacidade, buscar novas soluções e alternativas para alcançar a funcionalidade e os propósitos pretendidos, mas nunca perdendo de vista o fato de que os riscos à privacidade do usuário devem ser gerenciados de forma adequada.

5. Segurança de ponta a ponta: Proteção total do ciclo de vida

Este princípio prevê a adoção de medidas robustas de segurança de ponta a ponta, protegendo os dados coletados durante todo seu ciclo de vida.

O pressuposto deste princípio é que não existe privacidade sem segurança adequada. A segurança da informação envolve a confidencialidade, integridade, disponibilidade e resiliência dos sistemas que a armazenam.

A privacidade deve garantir a **possibilidade de desvinculação**, a **transparência** e a **capacidade de intervenção e controle** do titular dos dados no processamento.

Além disso, a adoção desse princípio implica que a organização deve prever métodos seguros de descarte e destruição do dado, de controle de acesso e de criptografia adequada.

Para integrar a privacidade em todas as etapas do processamento de dados, as diferentes operações envolvidas (coleta, registro, classificação, conservação, consulta, distribuição, limitação, apagamento, etc.) devem ser analisadas exaustivamente e, em cada caso, as medidas mais adequadas para a proteção da informação devem ser implementadas, dentre as quais estão:

- Técnicas precoces de pseudoanonimização ou anonimato, como k-anonimato.
- Classificação e organização das operações de processamento de dados com base em perfis de acesso.
- Criptografia padrão para que o estado “natural” dos dados, quando eventualmente roubados, seja “ilegível”.
- A destruição segura e garantida da informação no final do seu ciclo de vida.

6. Visibilidade e transparência: mantenha-o aberto

Um dos segredos para garantir a privacidade é poder demonstrá-la, verificando se o tratamento está de acordo com as informações prestadas.

A transparência no processamento de dados é essencial para demonstrar diligência e responsabilidade perante a Autoridade Supervisora e como uma medida de confiança perante os titulares dos dados.

Deve estar claro para o usuário/cidadão quais dados e em que medida serão tratados.

A promoção da transparência e visibilidade requer a adoção de uma série de medidas, tais como:

- Tornar públicas as políticas de privacidade e proteção de dados que regem o funcionamento da organização.
- Elaborar e publicar cláusulas de informação concisas, claras e compreensíveis que sejam facilmente acessíveis e que permitam aos titulares dos dados compreender o âmbito do tratamento dos seus dados, os riscos a que podem estar expostos, bem como a forma de exercer os seus direitos em matéria de proteção de dados.
- Embora não seja obrigatório para todos os responsáveis pelo tratamento, tornar pública ou, pelo menos, facilmente acessível aos titulares dos dados, a lista de todos os tratamentos efetuados na organização.
- Compartilhamento da identidade e detalhes de contato do controlador de dados da organização.
- Estabelecer mecanismos de comunicação, compensação e reclamação acessíveis, simples e eficazes para os titulares dos dados.

7. Respeito pela privacidade do usuário: mantenha-se centrado no usuário

Sem esquecer os legítimos interesses da organização no que diz respeito ao tratamento de dados que realiza, o objetivo final deve ser garantir os direitos e liberdades dos titulares cujos dados são processados e, portanto, qualquer medida adotada deve visar a garantia da sua privacidade.

Isso envolve a concepção de produtos “centrados no usuário”, antecipando suas necessidades.

O usuário deve desempenhar um papel ativo no gerenciamento de seus dados e no controle do que os outros fazem com eles. Todavia, como já explicado em um dos princípios acima, sua inação não pode implicar diminuição de sua privacidade.

A concepção de produtos que visam garantir a privacidade dos titulares dos dados envolve:

- Implementar configurações de privacidade que são “robustas” por padrão e onde os usuários são informados das consequências para sua privacidade quando os parâmetros estabelecidos são modificados.
- Disponibilizar informações completas e adequadas que conduzam a um consentimento informado, livre, específico e inequívoco que deve ser explícito em todos os casos que o requeiram.
- Proporcionar aos titulares dos dados acesso aos seus dados e a informações detalhadas sobre os objetivos de processamento e comunicações efetuadas.
- Implementar mecanismos eficientes e eficazes que permitam aos titulares dos dados exercer os seus direitos em matéria de proteção de dados.

4.3. REQUISITOS DE PRIVACIDADE DOS SISTEMAS

Para desenvolver sistemas confiáveis sob o ponto de vista da proteção de dados, é fundamental entender como o processamento de dados pessoais pode afetar a privacidade das pessoas.

No ordenamento jurídico nacional, a LGPD, em seu artigo 6º e respectivos incisos, enumera dez princípios que deverão ser observados em conjunto à boa-fé, em todas as atividades de tratamento de dados pessoais, quais sejam: ***finalidade, adequação, necessidade, livre acesso, qualidade dos dados, transparência, segurança, prevenção, não-discriminação e responsabilização e prestação de contas***.

A GDPR, por sua vez, em seu artigo 5, elenca seis princípios básicos que devem ser respeitados no processamento de dados, de modo que esses seis princípios (legalidade, justiça e transparência / limitação da finalidade / minimização de dados / exatidão / limitação de armazenamento / integridade e confidencialidade) se juntam e a responsabilidade passa a ser o núcleo e a meta que todo produto deve garantir em seu projeto, independentemente dos requisitos funcionais ou do próprio sistema.

4.4. OBJETIVOS DE PRIVACIDADE E SEGURANÇA

Tradicionalmente, o projeto de sistemas seguros e confiáveis se concentra na análise de riscos e na resposta a ameaças que afetam os objetivos de segurança mais voltadas para a privacidade, quais sejam:

- **CONFIDENCIALIDADE**, evitando o acesso não autorizado aos sistemas;
- **INTEGRIDADE**, protegendo-os de modificações não autorizadas de informações e;
- **DISPONIBILIDADE**, garantindo que os dados e sistemas estejam sempre disponíveis quando necessário.

Ocorre que, não obstante o acesso não autorizado e a modificação de dados pessoais possam se tornar um aspecto crítico que ameaça a privacidade dos indivíduos, há outros fatores de risco que podem surgir durante um processamento de dados autorizado e que devem ser identificados durante a avaliação de risco dos direitos e liberdades dos titulares dos dados.

Ao tratarmos de segurança e privacidade para sistemas, necessário compreendermos que há riscos para a privacidade que têm um efeito claro sobre os direitos e liberdades das pessoas e que não podem ser gerenciados usando-se apenas um modelo de risco tradicional que se concentre exclusivamente nos objetivos de segurança. Abaixo, rol não exaustivo de exemplos desses riscos:

- Perda de controle na tomada de decisão;
- Coleta excessiva de dados;
- Reidentificação;
- Discriminação e/ou estigmatização de pessoas;
- Preconceitos em decisões automatizadas;
- Falta de compreensão dos usuários sobre o escopo e os riscos de processamento ilegal;
- Definição de perfil que seja invasiva ou incorreta, etc.

Com o cenário supracitado em mente, bem como com os possíveis riscos para a privacidade, associados ao funcionamento planejado e autorizado de sistemas que coletam, usam e revelam dados pessoais, é necessário ampliar o âmbito da análise para incluir não só os riscos derivados de processamento não autorizado, mas também aqueles que podem surgir do processamento de informações planejado e autorizado. Bem como os apresentados pelos seguintes objetivos de proteção à privacidade, Figura 1:

- **DESVINCULABILIDADE**: procura processar dados de tal maneira que os dados pessoais dentro de um domínio não possam ser vinculados aos dados pessoais

em um domínio diferente, ou que o estabelecimento de tal ligação envolva um esforço desproporcional.

A desvinculabilidade minimiza o risco de utilização não autorizada de dados pessoais e a criação de perfis através da interligação de dados de diferentes conjuntos, estabelecendo garantias quanto aos princípios de limitação de finalidade, minimização de dados e limitação de armazenamento.

- **TRANSPARÊNCIA:** visa a esclarecer o processamento dos dados de forma que a coleta, o processamento e o uso das informações possam ser compreendidos e reproduzidos por todas as partes envolvidas e a qualquer momento durante o processamento.

Para obter transparência, necessário delinear o contexto de processamento e tornar as informações sobre os objetivos e as condições legais, técnicas e organizacionais aplicáveis a eles disponíveis antes, durante e após o processamento dos dados para todas as partes envolvidas, tanto para o controlador quanto para o sujeito cujos dados são processados, minimizando assim os riscos aos princípios de lealdade e transparência.

- **INTERVENIBILIDADE (CONTROLE):** garante que é possível às partes envolvidas no tratamento dos dados pessoais, e em particular aos sujeitos cujos dados são tratados, intervir no tratamento sempre que necessário para a aplicação de medidas corretivas ao tratamento da informação.

Este objetivo está intimamente ligado à definição e implementação de procedimentos para o exercício dos direitos de proteção de dados, apresentação de reclamações ou revogação do consentimento dado pelos titulares dos dados, bem como mecanismos para garantir a avaliação do cumprimento pelo responsável pelo tratamento dos dados e eficácia das obrigações que lhes são atribuídas por lei.

	OBJETIVOS DE PROTEÇÃO À PRIVACIDADE E RELAÇÃO COM OS PRINCÍPIOS DA LGPD E GDPR		
	DESVINCULABILIDADE	TRANSPARÊNCIA	CONTROLE
LGPD	• Necessidade • Prevenção	• Livre acesso • Finalidade • Transparência • Não-discriminação e responsabilização	• Adequação • Finalidade • Qualidade dos dados • Segurança • Não-discriminação e responsabilização • Prestação de contas

Figura 1 - Objetivos de proteção à privacidade e relação com os princípios da LGPD e GDPR

Esses três novos objetivos de proteção, somados aos objetivos de segurança existentes, estabelecem uma estrutura global de proteção no processamento de dados pessoais e determinam, por meio de uma avaliação de risco, outros atributos ou requisitos

não funcionais que o sistema deve satisfazer e que se tornam pontos de partida para o processo de projeto de privacidade.

4.5. PROJETANDO PRIVACIDADE

Quando falamos de privacidade desde o projeto, estamos falando de Engenharia de Privacidade, que é um processo sistemático com foco orientado ao risco, cujo objetivo é traduzir, em termos práticos e operacionais, os princípios da privacidade desde o projeto (PdP) dentro do ciclo de vida dos sistemas de informação encarregados do processamento de dados pessoais.

Podemos sintetizar esse processo conforme as ações abaixo descritas.

- Especificar as propriedades e funcionalidades de privacidade que devem ser cumpridas pelo sistema para que seu projeto e implementação sejam possíveis (**definição de requisitos de privacidade**);
- Projetar a arquitetura e implementar elementos de sistema que cobrem os requisitos de privacidade definidos (**projeto e desenvolvimento de privacidade**);
- Confirmar que os requisitos de privacidade definidos foram implementados corretamente e atendem às expectativas e necessidades das partes interessadas (**verificação e validação de privacidade**).

O diagrama da Figura 2 ilustra o processo de engenharia de privacidade.



Figura 2 - Processo de engenharia de privacidade

A privacidade deve ser uma parte integrada do projeto do sistema, de forma que os requisitos de privacidade sejam definidos em termos de propriedades e funcionalidades totalmente implementáveis e qualquer risco de privacidade identificado seja gerenciado adequadamente pelo sistema de forma proativa.

Para isso, é necessária uma abordagem sistemática e metodológica, transferindo o QUE das fases de desenvolvimento e análise do conceito (requisitos de privacidade identificados) para o COMO das fases de concepção e implementação (estratégias e soluções concretas), funcionando assim sequencialmente em diferentes níveis de abstração, Figura 3.



Figura 3 - Estratégias, padrões e tecnologias de privacidade dentro do ciclo de vida de um sistema

No nível mais alto, nos estágios iniciais de desenvolvimento (formulação do conceito) e na análise de seus requisitos (engenharia dos requisitos), é necessário trabalhar com [Estratégias de projeto de privacidade](#), abordagens gerais de alto nível destinadas a identificar táticas a serem seguidas durante as diferentes etapas do processamento de dados, de forma a garantir os objetivos de privacidade e o cumprimento dos princípios do processamento de dados já citados neste documento.

Essas estratégias servem como pontes entre os princípios de processamento impostos por lei e a implementação da privacidade em soluções concretas.

Como veremos mais adiante, elas estão centradas em responder a ações que podem representar uma ameaça à privacidade nas atividades de processamento e seu uso não é excludente.

Pelo contrário, é desejável que todos ou a maioria deles sejam aplicados de forma a tornar o objeto desenvolvido o mais amigável possível à privacidade.

As estratégias de projeto de privacidade são manifestadas, no nível mais baixo, em [padrões de projeto de privacidade](#).

Essas são soluções reutilizáveis que são empregadas no estágio de projeto e podem ser aplicadas para resolver problemas comuns de privacidade que frequentemente surgem no desenvolvimento de produtos e sistemas.

O objetivo desses padrões é criar um catálogo de soluções reutilizáveis no projeto de privacidade de sistemas e padronizar o processo de desenvolvimento.

A associação entre padrões e estratégias não é um a um, ou seja, um mesmo padrão pode implementar e responder a múltiplas estratégias de privacidade, fornecendo soluções para diferentes problemas que aparecem ao longo das atividades de processamento de dados.

Finalmente, no nível mais baixo, o estágio de desenvolvimento, encontramos as Privacy Enhancing Technologies (PETs) ou, em livre tradução, Tecnologias de Aprimoramento de Privacidade, as quais serão doravante nominadas pela sigla, em português, TAPs. As TAPs são usadas para implementar padrões de projeto de privacidade com uma tecnologia concreta.

A Comissão das Comunidades Europeias, na segunda página da sua [Comunicação ao Parlamento Europeu e ao Conselho sobre a Promoção da Proteção de Dados por Tecnologias de Aprimoramento da Privacidade](#), define-as como “um sistema coerente de medidas TIC que têm como objetivos proteger a privacidade, eliminando ou reduzindo dados pessoais, evitando os desnecessários e/ou o tratamento indesejado de dados pessoais, tudo sem perder a funcionalidade do sistema de informação.

Semelhante a padrões e estratégias de privacidade, uma única TAP pode ser usada para implementar várias soluções de padrão de projeto.

4.6. ESTRATÉGIAS DE PROJETO DE PRIVACIDADE

Este capítulo visa a definir e explicar a aplicação de oito [estratégias de projeto de privacidade](#), quais sejam, ‘minimizar’, ‘ocultar’, ‘separar’, ‘resumir’, ‘informar’, ‘controlar’, ‘aplicar’ e ‘demonstrar’.

Essas estratégias podem ser divididas em duas categorias: estratégias **orientadas a dados** e estratégias **orientadas a processos**, Figura 4.

A primeira categoria inclui as estratégias de ‘Minimizar’, ‘Ocultar’, ‘Separar’ e ‘Resumir’ e é de natureza mais técnica e se concentra no processamento amigável dos dados coletados.

A segunda categoria inclui as estratégias de ‘Informar’, ‘Controlar’, ‘Aplicar’ e ‘Demonstrar’. Estas são de natureza mais organizacional e orientadas para a definição de processos que implementem uma gestão responsável de dados pessoais.

RELAÇÃO ENTRE OBJETIVOS DE PRIVACIDADE E ESTRATÉGIAS DE PROJETO DE PRIVACIDADE		
OBJETIVO DE PROTEÇÃO DA PRIVACIDADE	ESTRATÉGIAS DE PROTEÇÃO DE PRIVACIDADE ORIENTADAS A DADOS	ESTRATÉGIAS DE PROTEÇÃO DE PRIVACIDADE ORIENTADA A PROCESSOS
DESVINCULABILIDADE	MINIMIZAR, RESUMIR, SEPARAR, OCULTAR	
CONTROLE		CONTROLAR, APLICAR, DEMONSTRAR
TRANSPARÊNCIA		INFORMAR

Figura 4 - Relação entre objetivos de privacidade e estratégias de projeto de privacidade

A depender do contexto, certas estratégias podem ser mais aplicáveis do que outras dentro do quadro de desenvolvimento de um sistema.

Essas oito estratégias, Figura 5, quando consideradas desde os estágios iniciais de desenvolvimento e análise do conceito e aplicadas em conjunto, permitem a inclusão de salvaguardas e medidas de proteção nas operações e procedimentos de tratamento de dados

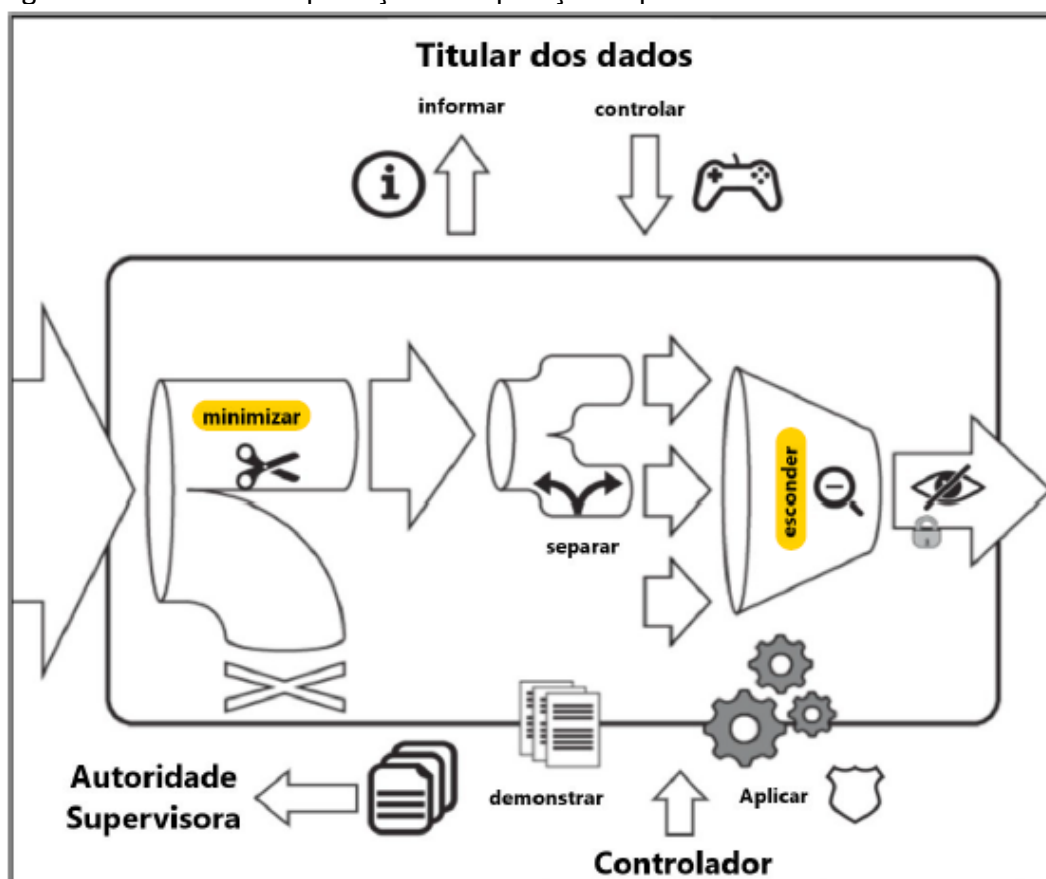


Figura 5 - Estratégias de Privacidade desde o Projeto e respectivos atores

MINIMIZAR

O objetivo dessa estratégia é coletar e processar a menor quantidade possível de dados, evitando o processamento de dados desnecessários e limitando possíveis impactos na privacidade.

Isso pode ser alcançado coletando dados de menos sujeitos (reduzindo o tamanho da população) ou menos dados de sujeitos (reduzindo o volume de informações coletadas), para os quais as seguintes táticas podem ser usadas:

- **Selecionar:** selecionar apenas a amostra de indivíduos relevantes e os atributos exigidos, com uma abordagem conservadora ao estabelecer os critérios de seleção e processar apenas os dados que satisfaçam os critérios de seleção (lista permitida).
- **Excluir:** é o inverso da abordagem anterior e consiste em excluir de antemão assuntos e atributos irrelevantes para o processamento (lista proibida). Nesse caso, deve-se adotar uma atitude aberta, excluindo o máximo de informações possível, a menos que sua inclusão possa ser justificada como sendo absolutamente necessária para o objetivo pretendido.
- **Retirar:** elimina parcialmente os dados pessoais assim que deixem de ser necessários, o que implica estabelecer previamente o período de armazenamento de cada um dos dados recolhidos e estabelecer mecanismos de eliminação automática quando esse período terminar. Caso os dados façam parte de um registro que contenha mais informações do que o necessário, o valor dos campos desnecessários pode ser modificado para um valor padrão prefixado.
- **Destruir:** elimina completamente os dados pessoais assim que deixem de ser relevantes, garantindo que é impossível recuperar os dados e quaisquer cópias de segurança.

Também é importante lembrar que apenas os dados estritamente necessários devem ser comunicados e compartilhados, e em caso de processamento em que novas informações pessoais sejam extrapoladas, os dados gerados que não sejam necessários para atingir o objetivo pretendido também devem ser excluídos.

OCULTAR

O foco desta estratégia é limitar a visibilidade dos dados, estabelecendo os meios necessários para garantir a proteção da confidencialidade e desvinculação. As seguintes táticas são usadas para implementar esta estratégia:

- **Restringir:** restringir o acesso aos dados pessoais estabelecendo limites através de uma política de controle de acesso que implementa um princípio de “necessidade de saber” tanto no espaço (detalhes e tipo de dados acessados) quanto no tempo (etapas de processamento).

- **Ofuscação:** torna os dados pessoais ininteligíveis para quem não está autorizado a consultá-los, utilizando técnicas de criptografia e hashing, tanto para operações de armazenamento como para transmissão de informações.
- **Dissociar:** eliminar a ligação entre os conjuntos de dados que deveriam ser mantidos independentes, bem como os atributos de identificação dos registros de dados para evitar correlações entre eles, com atenção especial aos metadados.
- **Misturar:** agrupar informações sobre vários assuntos usando técnicas de generalização e supressão para evitar correlações.

SEPARAR

O objetivo desta estratégia é evitar, ou pelo menos minimizar o risco de que durante o processamento, dentro de uma entidade, diferentes dados pessoais do mesmo indivíduo que são usados em processos independentes, possam ser combinados para criar um perfil completo do titular dos dados.

Para isso, é necessário manter contextos de processamento independentes que dificultam a correlação de conjuntos de dados que deveriam ser desvinculados.

As seguintes táticas ajudam a implementar uma estratégia de separação:

- **Isolar:** recolher e armazenar dados pessoais em diferentes bases de dados ou aplicações independentes, de forma lógica ou executadas em diferentes sistemas físicos, adotando medidas adicionais para garantir a desvinculabilidade, como a eliminação programada de índices da base de dados.
- **Distribuir:** distribuir a coleta e o processamento de diferentes subconjuntos de dados pessoais correspondentes a diferentes tipos de processamento em unidades de gerenciamento e manuseio que são fisicamente independentes dentro do sistema e usar diferentes sistemas e aplicativos para implementar arquiteturas descentralizadas e distribuídas que processam as informações localmente sempre que possível, ao invés de usar soluções centralizadas com acesso unificado que pode depender de uma única unidade de controle.

RESUMIR

A ideia por trás desta estratégia é limitar os detalhes dos dados pessoais processados, tanto quanto possível.

Enquanto a estratégia de 'minimizar' faz uma seleção prévia dos dados a serem coletados, esta estratégia se concentra no grau de detalhe em que os dados são processados e em sua agregação usando três táticas:

- **Sumarizar:** generalize os valores dos atributos usando faixas ou intervalos de valor, ao invés de um valor de campo concreto.

- **Agrupar:** agregar as informações de um grupo de registros em categorias ao invés de usar as informações detalhadas sobre cada um dos assuntos que pertencem ao grupo, por meio de valores médios ou gerais.
- **Perturbar:** use valores aproximados ou modifique os dados reais usando algum tipo de ruído aleatório em vez de empregar o valor exato dos dados pessoais.

Para cada processamento de dados, é necessário estudar como o nível de detalhe dos dados inseridos afeta o resultado e qual é o grau de precisão necessário para um processamento eficaz.

Especialmente, o período de tempo após a coleta dos dados pode afetar sua relevância, por isso é útil revisar periodicamente as informações armazenadas e aplicar essas estratégias.

INFORMAR

Essa estratégia traz concretude aos objetivos e princípios de transparência elencados tanto na [LGPD \(arts. 2º, 6º, 8º, 9º, 14, 18, 20, 23, 25, 29 e 48\)](#) quanto na GDPR (arts. 13 e 14).

A transparência no que diz respeito a essas informações é um requisito básico de privacidade, pois permite que os titulares dos dados tomem decisões informadas sobre o processamento e, conseqüentemente, forneçam consentimento livre, específico, informado e inequívoco.

Qualquer modificação no processamento das informações fornecidas anteriormente deve ser comunicada, incluindo possíveis violações de segurança que podem afetar significativamente os direitos e garantias dos titulares dos dados.

Esta estratégia baseia-se na existência de cláusulas de privacidade que facilitam a comunicação global desta informação aos titulares dos dados, juntamente com a utilização das seguintes táticas:

- **Fornecimento:** fornecer aos titulares dos dados todas as informações exigidas pela LGPD sobre quais dados pessoais são processados, como são processados e por quê, identificando o motivo e o objetivo. Devem ser fornecidos detalhes sobre os períodos de armazenamento de dados, bem como sobre o compartilhamento desses dados com terceiros.

Juntamente com esta informação, que deve ser acessível e disponibilizada continuamente de forma a promover uma transparência autêntica, deve indicar também quem pode ser contactado pelos titulares dos dados e como, para colocar questões sobre a sua privacidade e os seus direitos a respeito da proteção de dados pessoais.

- **Explicação:** fornecer informações sobre o processamento de dados de forma concisa, transparente, inteligível e facilmente acessível em linguagem clara e simples.

Para evitar políticas de informação densas, complexas e difíceis de manejar, vale a pena adotar uma [abordagem em camadas](#) que primeiro fornece informações básicas ao mesmo tempo e dentro do mesmo meio de coleta de dados e disponibiliza informações adicionais detalhadas em um segundo nível.

- **Notificação:** Notificar os usuários (em tempo real) no momento em que você processa seus dados pessoais, compartilha-os com terceiros, ou assim que você tomar conhecimento de um vazamento de dados.

Prepare procedimentos claros para isso. Fazer notificações sucintas, mas informativas.

Certificar-se de não notificar com muita frequência. Permitir aos usuários controlar sobre quais eventos eles desejam receber uma notificação. Os usuários também devem ser informados se seus dados serão transferidos a terceiros. Também devem ser implementados mecanismos para notificar os sujeitos sobre as violações de segurança que possam ter ocorrido e possam representar um risco grave para seus direitos e garantias, utilizando uma linguagem clara e simples para descrever a natureza da violação.

Considerando que os procedimentos de coleta de dados são variados, os meios de notificação devem ser adaptados às circunstâncias de cada método utilizado, incluindo, adicionalmente, a possível utilização de ícones padronizados que ofereçam uma visão geral do processamento antecipado.

CONTROLAR

Esta estratégia está intimamente ligada à estratégia de 'informar' e visa proporcionar aos sujeitos o controle sobre a coleta, o tratamento, a utilização e a transferência dos seus dados pessoais por meio da implementação de mecanismos que lhes permitam exercer os seus direitos de acesso, retificação, apagamento, objeção, portabilidade e restrição de seus dados e seu processamento, bem como o direito de dar e retirar consentimento ou modificar opções de privacidade nos produtos.

Para implementar esses mecanismos, as seguintes táticas são usadas:

- **Consentimento:** Peça aos usuários consentimento explícito para o processamento de seus dados pessoais fornecidos. Informe-os de antemão exatamente sobre quais dados pessoais serão processados, como serão processados e para que finalidade ('consentimento informado', consulte também a estratégia de informar). Deve ser possível retirar o consentimento.
- **Alerta:** para fornecer notificação em tempo real ao usuário no momento da coleta de dados pessoais, mesmo quando a informação geral sobre a base legal do tratamento tenha sido fornecida ou mesmo quando o sujeito já tenha dado o seu consentimento. Essa funciona como uma tática adicional para garantir de forma inequívoca o entendimento e consentimento do usuário.

- **Escolha:** oferecer aos usuários uma escolha real: a funcionalidade básica deve ser acessível para pessoas que não consentem com o processamento de seus dados pessoais dados. Um exemplo comum de uso dessa tática é em aplicativos que, em sua modalidade gratuita, coleta dados e dá menos opções de controle ao usuário; por outro lado, oferece versões pagas em que o usuário pode ter controle total de seus dados. Para o fim a que se destina o presente documento (guia para desenvolvimento no âmbito do MPF), importante observar a máxima aderência aos normativos em vigor, em especial, a LGPD.
- **Atualização:** implementar mecanismo que facilite ou mesmo permita que façam revisões, atualizações e retificações diretas dos dados fornecidos para um processamento específico, de forma que sejam precisos e reflitam a realidade. Uma forma prática de fazer isso é por meio de um dashboard, um painel de privacidade.
- **Retirada:** Oferecer aos usuários um meio de retirar (ou solicitar a exclusão de) seus dados pessoais. Novamente, o uso de um painel de privacidade se mostra como uma forma bem prática para implementar esta tática.

Interessante ter-se em mente que os avanços tecnológicos que permitem a coleta contínua de dados também possibilitam que os dados sejam facilmente geridos pelos titulares dos dados através da implementação de plataformas de privacidade onde podem acessar, atualizar, cancelar e modificar as definições de privacidade selecionadas. É recomendável que essas funções sejam consideradas ao projetar um aplicativo.

APLICAR

Esta estratégia está relacionada apenas indiretamente com o desenvolvimento de aplicativos e sistemas propriamente dito. Ela se relaciona diretamente com a Administração.

A instituição deve comprometer-se a processar dados pessoais de forma amigável à privacidade, e implementar isso adequadamente.

Esta estratégia garante que o tratamento de dados pessoais seja compatível e respeite os requisitos legais e os deveres impostos pela regulamentação.

Para tal, é necessário definir um quadro de privacidade e uma estrutura administrativa que inclua uma política de proteção de dados suportada pelos níveis superiores de gestão, bem como as funções e responsabilidades que lhe são cometidas para o seu cumprimento.

A cultura de privacidade deve ser uma parte essencial da organização e todos os membros devem ser participantes.

As seguintes táticas podem ajudar a implementar isso:

- **Criar:** Especifique uma política de proteção de dados que reflita internamente as cláusulas de privacidade que são comunicadas aos titulares dos dados.

Devem ser criadas as estruturas necessárias e atribuídos recursos para apoiar esta política e garantir que as atividades de processamento da organização respeitam e cumprem os regulamentos de proteção de dados.

Também deve ser desenvolvido um plano de treinamento e conscientização para todos os integrantes, visando assegurar uma postura comprometida e responsável como parte da prestação de contas.

- **Manter:** Manter a política com todos os controles técnicos e organizacionais necessários. Implemente esses controles. Atribua responsabilidades. Crie uma campanha de conscientização e treine todo o pessoal. Certifique-se de que eventuais terceiros (processadores) também cumpram a política.
- **Sustentar/Apoiar:** Esteja atento para a mudança de circunstâncias. Verifique a política de privacidade regularmente e ajuste sua implementação sempre que necessário. Estabeleça critérios prévios e avalie sua política em relação a eles.

A política de privacidade deve estar alinhada com o plano geral de negócios e declaração de missão do MPF. Certifique-se de que é consistente com todas as outras políticas organizacionais da instituição.

Nesse panorama, a figura do Data Protection Officer (DPO) desempenha um papel fundamental na implementação desta estratégia, avaliando o controlador e fiscalizando o cumprimento das normas de proteção de dados na organização.

Implementar modelos de gerenciamento de privacidade como o recentemente proposto pela norma ISO/IEC 27701:2019 também é eficaz. Ela lista os requisitos e fornece orientações para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gerenciamento de Informações de Privacidade.

DEMONSTRAR

Demonstre que você está processando dados pessoais de maneira amigável à privacidade. Essa estratégia aborda o novo requisito de que as organizações precisam demonstrar conformidade com os regulamentos de privacidade. A estratégia de demonstração é orientada externamente, para as autoridades de proteção de dados (possivelmente por meio do responsável pela proteção de dados interno).

As táticas a seguir ajudam as organizações a demonstrar conformidade:

- **Registrar:** Documente todas as etapas (importantes) adotadas. Registre as decisões e motive-as. Colete logs do sistema (e responda a anomalias). Identifique quem tomou a decisão, quando e por quê.
- **Auditoria:** Auditar os logs regularmente, mas também auditar os processos organizacionais em geral e a forma como os dados pessoais são processados dentro da organização. Recomendável que seja uma análise sistemática, independente e documentada do grau de cumprimento da política de proteção de dados.

- **Relatório:** documenta os resultados das auditorias e quaisquer outros incidentes relacionados com operações de tratamento de dados pessoais e disponibiliza-os às autoridades de supervisão sempre que necessário.

Realizar uma análise de risco e, quando aplicável, uma avaliação do impacto da proteção de dados juntamente com a documentação sobre as decisões tomadas em relação aos resultados, é um bom começo para estabelecer os requisitos de privacidade que devem ser implementados em aplicativos e sistemas como parte da privacidade desde o projeto, bem como documentar totalmente como os dados pessoais são processados e seguir o princípio da responsabilidade.

Na Tabela 1, veremos Estratégias de projeto de privacidade, orientadas a dados e a processos, juntamente com táticas e padrões de privacidade para sua implementação.

ESTRATÉGIA DE PROJETO DE PRIVACIDADE		DESCRIÇÃO E TÁTICAS	CONTROLE E PADRÕES DE PROJETO
ESTRATÉGIAS ORIENTADAS A DADOS	Minimizar	Limite o processamento de dados pessoais tanto quanto possível. TÁTICAS: selecionar, excluir, retirar e destruir	Anonimização Pseudonimização Bloco correlativo em sistemas de gerenciamento de identidade federada
	Esconder	Evite tornar os dados pessoais públicos ou conhecidos TÁTICAS: restringir, ofuscar, dissociar e misturar)	Encriptação Mix Networks Credenciais Baseadas em Atributos
	Separar	Mantenha os conjuntos de dados pessoais separados. TÁTICAS: isolar e distribuir	Listas negras anônimas Criptografia homomórfica Separação física e lógica
	Resumir	Limite o nível de detalhe usado no processamento de dados pessoais tanto quanto possível. TÁTICAS: resumir, agrupar e perturbar	Grupo baseado em tempo K-anonimato Ofuscação de medição de ruído adicionado Granularidade de localização dinâmica Privacidade diferencial
ESTRATÉGIAS ORIENTADAS A PROCESSOS	Informar	Mantenha os titulares dos dados informados sobre a natureza e as condições de processamento. TÁTICAS: fornecer, explicar e notificar	Notificações de violação de segurança; Visualização dinâmica da política de privacidade; Ícones de privacidade; Avisos ambientais

Controlar	Forneça aos titulares dos dados um controle efetivo sobre seus dados pessoais. TÁTICAS: consentir, alertar, escolher, atualizar, retirar	Painel de privacidade; Transmissão ativa de presença; Seleção de credencial; Consentimento informado
Aplicar	Respeite e promova o cumprimento das obrigações estabelecidas pela regulamentação em vigor e pela própria política de proteção de dados. TÁTICAS: criar, manter, defender	Avaliação do impacto da privacidade em soluções de gerenciamento de identidade federada; Controle de acesso. Gestão de obrigações. Aderência às políticas
Demonstrar	Seja capaz de demonstrar que o processamento de dados respeita a privacidade. TÁTICAS: registrar, auditoria e relatório.	Auditoria; Logs (histórico)

Tabela 1 - Estratégias Orientadas a Dados e a Processos

4.7. PADRÕES DE PROJETO DE PRIVACIDADE

Após a definição dos objetivos e estratégias de privacidade a serem incluídos no produto como parte de sua definição, é necessário integrá-los em seu projeto.

Para isso, os padrões de projeto de privacidade são usados como soluções reutilizáveis para resolver problemas comuns e reiterados de privacidade que aparecem repetidamente em um contexto específico durante o desenvolvimento de produtos e sistemas.

A descrição do padrão de projeto contém, pelo menos, seu nome, sua finalidade, seu contexto de aplicação, objetivos, estrutura, implementação (relação com outros padrões), as consequências de sua aplicação e usos conhecidos.

Um padrão de projeto pode ser usado para implementar mais de uma estratégia de privacidade e, portanto, essas não são soluções fechadas e exclusivas; em vez disso, devemos olhar para as estratégias de privacidade de um foco combinado e geral.

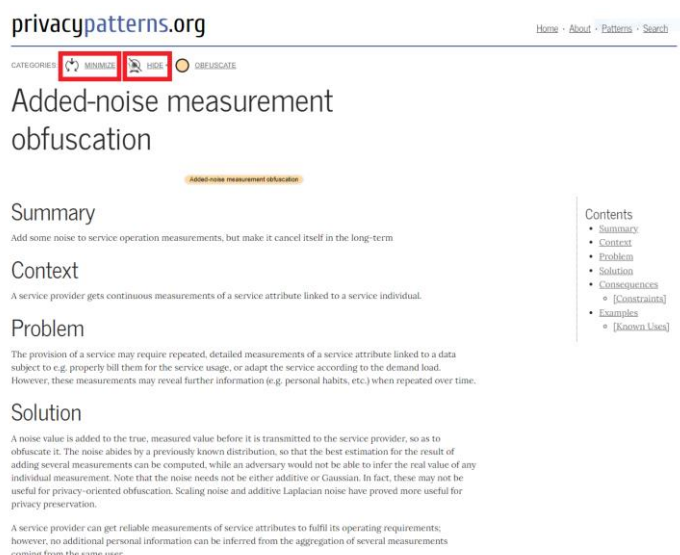


Figura 6 - Padrão de Obscurecimento de medição de ruído adicionado

Por exemplo, conforme a Figura 6, o padrão de '[obscurecimento de medição de ruído adicionado](#)' (livre tradução), que adiciona ruído a medições reais tomadas durante a operação de um serviço para que informações adicionais não possam ser extrapoladas, nos permite implementar as estratégias de 'ocultar' e 'minimizar' ao mesmo tempo.

4.8. CATÁLOGOS DE PADRÕES DE PROJETO

Atualmente, existem diferentes coleções ou catálogos de padrões de projeto de privacidade onde podemos encontrar definições abrangentes, seus objetivos e informações sobre como usá-los.

Em 2013, a União Europeia iniciou o financiamento do [PRIPARE \(PReparing Industry to Privacy by design by support your Application in Research\)](#). Por meio desse projeto, foi desenvolvido um catálogo de 26 padrões de projeto de privacidade.

Iniciativa semelhante foi o resultado de um projeto realizado na Universidade de Economia e Negócios de Viena, que cria [um repositório interativo de soluções](#) que classifica 40 padrões de projeto de privacidade pelos 11 princípios de proteção definidos pelo padrão da norma [ISO / IEC 29100:2011](#).

Por fim, há outra iniciativa colaborativa entre vários centros e universidades, dentre eles o Berkeley Center for Law and Technology, a Universidade de Economia e Negócios de Viena e a Universidade Politécnica de Madrid, que desenvolveu um [catálogo de padrões](#) com o fim de padronizar a linguagem para tecnologias de preservação de privacidade, de documentar soluções comuns para problemas de privacidade e ajudar os designers a identificar e abordar questões de privacidade.

4.9. TECNOLOGIAS DE AUMENTO DA PRIVACIDADE (TAPs)

Realizadas as etapas de 1) estabelecer as estratégias de privacidade aplicáveis ao projeto, 2) escolher as respectivas táticas de implementação das estratégias, 3) definir os padrões de privacidade em conformidade com propósito, chega o momento da implementação na etapa de desenvolvimento, usando uma solução tecnológica adequada.

As [Tecnologias de Aumento de Privacidade \(TAPs\)](#), são um grupo organizado e coerente de soluções de TIC que reduzem os riscos de privacidade ao implementar as estratégias e padrões previamente definidos.

Devido ao contexto tecnológico em mudança, a sua eficácia, em termos de proteção da privacidade, muda de uma TAP para outra com base no tempo, sendo tarefa árdua fornecer uma classificação e tipologia atualizadas.

Uma TAP pode ser uma ferramenta independente comprada e instalada pelo usuário final em seu computador pessoal ou uma estrutura complexa de sistemas de informação.

4.9.1. CLASSIFICAÇÃO DAS TAPs

Existem várias classificações de TAPs, a maioria delas com base em características técnicas. Entretanto, outra classificação possível dessas ferramentas é baseada nas [finalidades a que se destinam](#). Para os fins didáticos relacionados ao objetivo deste documento, utilizaremos essa última classificação.

Portanto, usaremos a classificação de acordo com o objetivo de **proteger a privacidade** ou **gerenciá-la**, mantendo assim um foco consistente com a classificação de estratégias que foi discutida anteriormente, Figura 7.

O primeiro grupo combina ferramentas e tecnologias que protegem ativamente a privacidade durante o processamento de dados pessoais (por exemplo, ocultando dados pessoais ou eliminando a necessidade de identificação).

O segundo grupo lida com ferramentas e tecnologias que suportam procedimentos relacionados ao gerenciamento de privacidade, mas não operam ativamente nos dados.

CATEGORIA	SUBCATEGORIA	DESCRIÇÃO
PROTEÇÃO DE PRIVACIDADE	Ferramentas de pseudonimização	Permitir transações sem pedir informações pessoais
	Produtos e serviços de anonimização	Fornecer acesso aos serviços sem exigir a identificação do titular dos dados.
	Ferramentas de criptografia	Protege documentos e transações de serem vistos por terceiros
	Filtros e bloqueadores	Evitam e-mails e conteúdo da web indesejados
	Anti-trackers	Elimina rastros digitais do usuário
GESTÃO DA PRIVACIDADE	Ferramentas de informação	Criam e verificam as políticas de privacidade
	Ferramentas administrativas	Gerencia identidade e permissões do usuário

Figura 7 - Padrão de Obscurecimento de medição de ruído adicionado

4.9.2. CATÁLOGO DE TECNOLOGIAS DE AUMENTO DE PRIVACIDADE (TAPs)

Atualmente, da mesma forma que ocorre com os padrões de projeto de privacidade, não há um catálogo unificado de ferramentas e tecnologias TAP, embora existam algumas iniciativas diferentes.

A Technology Analysis Division of the Office of the Privacy Commissioner of Canada, ou Divisão de Análise de Tecnologia do Escritório do Comissário de Privacidade do Canadá (em livre tradução) desenvolveu uma [visão geral das TAPs com base em sua funcionalidade](#) e deu alguns exemplos concretos de soluções.

O Centro para Internet e Sociedade (CIS) da Faculdade de Direito da Universidade de Stanford (Califórnia) publicou um [banco de dados de ferramentas e tecnologias TAP](#) como um wiki de código aberto, para que os usuários possam ter melhor controle sobre seus dados pessoais.

No continente europeu, a European Data Protection Supervisor (EDPS), ou Autoridade Europeia de Proteção de Dados (livre tradução) desenvolveu o [IPEN \(Internet Privacy Engineering Network\)](#), com o objetivo de apoiar os desenvolvedores na utilização de padrões de projeto de privacidade e outros blocos reutilizáveis que visam proteger e melhorar a privacidade de uma forma mais eficiente e eficaz.

Em 2015, a European Union Agency for Network and Information Security (ENISA) realizou o estudo “[Ferramentas de privacidade online para o público em geral](#)”, que analisou ferramentas TAP para proteção da privacidade online e compilou uma lista de portais que promovem a utilização desta tecnologia e podem ser uma ótima referência.

Embora as ferramentas sugeridas nos portais exibidos na tabela abaixo sejam geralmente aplicativos de software destinados a usuários finais para melhorar sua proteção de dados pessoais, sua análise e estudo também são úteis para controladores de dados como exemplos de requisitos de privacidade que devem ser incluídos em serviços, produtos e aplicativos a serem desenvolvidos.

Se essas soluções (criptografia segura de comunicações, anonimizadores, anti-rastreadores, etc.) forem integradas em série nos sistemas, elas evitarão que os usuários finais fiquem desprotegidos ou tenham que adicionar uma camada de privacidade posteriormente.

Nas referências bibliográficas descritas na Tabela 2 encontram-se algumas sugestões de leitura relativa a evolução das ferramentas TAP, desenvolvimento de uma metodologia para comparar a maturidade dessas ferramentas, dentre outros.

WEBSITE	ORGANIZAÇÃO	DESCRIÇÃO
Secure Messaging Scorecard	Electronic Frontier Foundation (EFF)	Uma apresentação e avaliação de aplicativos e ferramentas de mensageria seguro, usando uma lista de critérios predefinidos.
PRISM Break	Nylira (Peng Zhong)	Uma seleção de ferramentas para evitar rastreamento e vigilância em massa, como ferramentas de criptografia, anonimato, etc.
Security in-a-box	Electronic Privacy Information Center (EPIC)	Um site de segurança para uso geral que inclui ferramentas de proteção de privacidade, como ferramentas de criptografia.
EPIC Online Guide to Practical Privacy Tools	Electronic Privacy Information Center (EPIC)	Oferece listas de ferramentas de privacidade, organizadas de acordo com diferentes áreas (complementos do navegador, anonimizadores, etc.).
The Ultimate Privacy Guide	BestVPN (4Choice Ltd)	Um site de segurança para usuários em geral que oferece listas de VPNs comerciais. O guia de privacidade fornece uma lista de ferramentas classificadas de acordo com a área.
Free Software Directory	Free Software Foundation (FSF)	Um site para usuários em geral com informações sobre freeware de segurança e privacidade, com foco principalmente em criptografia.
Privacytools.io	Privacytools.io	Oferece listas de ferramentas para proteger a privacidade, como VPNs, complementos do navegador, etc.
Me & My Shadow	Tactical Technology Collective	Um site com foco principalmente em pegadas digitais e rastreamento online. Oferece recomendações sobre várias ferramentas relevantes.
Gizmo's Freeware	Gizmo's Freeware	Site de freeware de uso geral, que também é uma lista de ferramentas de privacidade de código aberto.
Best Privacy Tools	Best Privacy Tools	Oferece uma lista de ferramentas de privacidade, especialmente aplicativos de mensagens, VPN, navegação segura, etc.

Internet Privacy Tools	Internet Privacy Tools	Oferece uma lista de ferramentas de privacidade especialmente filtros de e-mail, criptografia baseada em navegador, etc.
Reset The Net Privacy Pack	Fight for the Future and Center for Rights	Oferece uma lista de ferramentas de privacidade gratuitas e conselhos pertinentes (por exemplo, comunicações seguras, navegação anônima, etc.).

Tabela 2 - Referências bibliográficas

4.10. CONCLUSÕES

Quando falamos sobre Privacy By Design ou Privacy and Security by Design, estamos falando de engenharia de softwares e aplicativos. Ao mesmo tempo estamos falando de dados pessoais e direitos fundamentais.

Nesse panorama, diariamente organizações e empresas desenvolvem serviços baseados na utilização intensiva de dados pessoais e cujo impacto na privacidade é visivelmente potencializado pela utilização de tecnologias disruptivas. Assim, torna-se necessária a adoção de medidas técnicas e organizacionais eficazes e eficientes que garantam que os direitos e liberdades das pessoas sejam respeitados no que tange o tratamento de dados pessoais.

À luz da LGPD, é imperativo garantir a privacidade e estabelecer um quadro de governança que garanta a proteção dos dados pessoais e não represente um obstáculo à inovação.

Garantir a privacidade é de fato uma inovação em si e introduz uma nova disciplina tecnológica: a engenharia de privacidade.

A implementação eficiente e eficaz dos princípios de privacidade exige que eles sejam parte integrante da natureza dos produtos e serviços e, para isso, devem ser levados em consideração desde os estágios iniciais de conceito, projeto e desenvolvimento propriamente dito como outra parte do conjunto de especificações funcionais e não funcionais.

Essa abordagem, como exaustivamente explanado nesse documento, é conhecida como Privacy by Design, ou – em livre tradução – Privacidade desde o Projeto.

A privacidade desde o projeto envolve o uso de um enfoque metodológico centrado na gestão de riscos e na responsabilidade que nos permite determinar os requisitos de privacidade por meio de práticas, procedimentos e ferramentas.

Dessa forma:

- **A análise de risco estabelecerá os objetivos específicos de proteção de dados** (desvinculabilidade, transparência e intervenibilidade), bem como **objetivos de segurança na perspectiva da privacidade** (confidencialidade, disponibilidade e integridade) que garantam os [princípios básicos estabelecidos, no artigo 6.º da LGPD](#).

- **A seguir, as estratégias de privacidade orientadas a dados e a processos que especificam os requisitos de cada objetivo de privacidade devem ser estudadas.**

Essas estratégias são: 'minimizar', 'ocultar', 'separar', 'abstrair', 'informar', 'controlar', 'aplicar' e 'demonstrar', e para cada uma delas, as táticas de proteção que implementam essas estratégias de forma eficaz devem ser definidas.

- **Na fase de projeto, as táticas selecionadas devem ser integradas por meio de soluções disponíveis, ou seja, padrões de projeto de privacidade que tratem de problemas comuns e reiterados, acessando os catálogos disponíveis, dos quais uma seleção é apresentada neste documento.**
- **Finalmente, no estágio de desenvolvimento, esses padrões devem ser implementados.** Esta implementação deve ser realizada por equipes de desenvolvimento através da programação do código com a funcionalidade necessária ou, sempre que possível, por meio da utilização de soluções TIC existentes, ou seja, tecnologias de aumento da privacidade, TAPs.

Em todos os casos, a proteção de dados desde a concepção é responsabilidade de todos envolvidos no tratamento de dados e estes devem trabalhar para garanti-la por quaisquer meios possíveis de desenvolvimento, aquisição ou subcontratação de sistemas, produtos ou serviços, sem, todavia, delegar totalmente a terceiros (fabricantes e processadores) a responsabilidade de implementar este princípio.

Como parte do cumprimento de seu dever, o Responsável pelo tratamento de dados, deve participar ativamente das tarefas de engenharia de privacidade, definindo os requisitos que devem ser levados em consideração, monitorando continuamente sua correta implementação e verificando sua plena operacionalidade antes da produção do sistema, para que a privacidade das pessoas cujos dados devem ser processados seja garantida.

5. CONSIDERAÇÕES FINAIS DA ORIENTAÇÃO TÉCNICA

Tendo em vista o exposto no presente documento, reforça-se a importância e a necessidade da utilização da Orientação Técnica, em questão, para o desenvolvimento de soluções de tecnologia dada a relevância do tema e para que haja o cumprimento do que está estabelecido na LGPD de proteção dos direitos fundamentais de liberdade e de privacidade e a livre formação da personalidade de cada indivíduo.

6. REFERÊNCIAS BIBLIOGRÁFICAS POR TEMA

PRIVACIDADE DESDE O PROJETO

Cavoukian, A. **Privacy by design: the definitive workshop. A foreword by Ann Cavoukian, Ph.D.** 2010. Disponível em: <<https://link.springer.com/content/pdf/10.1007/s12394-010-0062-y.pdf>>. Acesso em: 06/04/2022.

Resolution on Privacy by Design. 32nd International Conference of Data Protection and Privacy Commissioners. 2010. Disponível em: <https://edps.europa.eu/sites/edp/files/publication/10-10-27_jerusalem_resolutionon_privacybydesign_en.pdf>. Acesso em: 06/04/2022.

General Data Protection Regulation (EU) 2016/679. 2016. Disponível em: <<https://eurlex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32016R0679>>. Acesso em: 06/04/2022.

Artigo 25 “Data protection by design and by default” - General Regulation (EU) 2016/679, on Data Protection. 2016. Disponível em: <<https://eurlex.europa.eu/legal-content/ES/TXT/HTML/?uri=CELEX:32016R0679&from=E N #d1e3126-1-1>>. Acesso em: 06/04/2022.

Opinion 5/2018 Preliminary Opinion on Privacy by design. European Data Protection Supervisor (EDPS), 2018. Disponível em: <https://edps.europa.eu/sites/edp/files/publication/18-05-31_preliminary_opinion_on_privacy_by_design_en_0.pdf>. Acesso em: 06/04/2022.

Privacy and Data Protection by Design – from policy to engineering, European Union Agency for Cybersecurity (ENISA). 2014. Disponível em: <https://www.enisa.europa.eu/publications/privacy-and-data-protection-by-design/at_download/fullReport>. Acesso em: 06/04/2022.

Data protection by design and default. Information Commissioner’s Office (ICO), Disponível em: <<https://ico.org.uk/for-organisations/guide-to-dataprotection/guide-to-the-general-dataprotection-regulation-gdpr/accountability-and-governance/data-protection-by-design-anddefault/>>. Acesso em: 06/04/2022.

Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default, Version 2.0. European Data Protection Board – edpb, 2020. Disponível em: Procedimento 1.00.000.019690/2021-58, Documento 20.1, Página 35 <https://edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_201904_dataprotection_by_design_and_by_default_v2.0_en.pdf>. Acesso em: 19/4/2022.

Lister, John. **Practical Guide to Privacy by Design.** FreePrivacyPolicy, 2020. Disponível em: <https://www.freeprivacypolicy.com/blog/privacy-by-design/#Background_Of_Privacy_By_Design <https://piiano.com/blog/practical-guide-to-privacy-by-design-architecture/>>. Acesso em: 06/04/2022.

Garcia, A. C. et al. **Privacy- and Security-by-Design Methodology Handbook**. 2015. Disponível em:
<https://ipen.trialog.com/images/ipen/a/a1/PRIPARE_Methodology_Handbook_Final_Feb_24_2016.pdf>. Acesso em: 06/04/2022.

Implementing Privacy By Design. PrivacyPolicies, 2021. Disponível em:
<<https://www.privacypolicies.com/blog/privacy-by-design/>>. Acesso em: 06/04/2022.
Software development with Data Protection by Design and by Default. Disponível em:
<<https://www.datatilsynet.no/en/about-privacy/virksomhetenes-plikter/innebygd-personvern/dataprotection-by-design-and-by-default/?print=true>>. Acesso em: 06/04/2022.

PRivacy Enabled Capability In Co-Operative Systems and Safety Applications - Guidelines for Privacy Aware Cooperative Application. 2011. Disponível em:
<<https://cordis.europa.eu/docs/projects/cnect/1/224201/080/deliverables/001-PRECIOUSAD11GuidelinesPrivacyAwareCooperativeApplicationv13.pdf>> . Acesso em: 06/04/2022.

Data protection by design and default. Information Commissioner's Office. Disponível em:
<<https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/accountability-and-governance/data-protection-by-design-and-default/>>. Acesso em: 06/04/2022.

PRINCÍPIOS DE PRIVACIDADE DESDE O PROJETO

Cavoukian, A. **Privacy by Design: The 7 Foundational Principles**. 2011. Disponível em:
<<https://www.ipc.on.ca/wp-content/uploads/Resources/7foundationalprinciples.pdf>>.
Acesso em: 06/04/2022.

Cavoukian, A. **Operationalizing Privacy by Design: A guide to implementing strong privacy practices**. 2012. Disponível em:
<<https://www.schwaab.ch/wp-content/uploads/2013/09/operationalizing-pbd-guide.pdf>>.
Acesso em: 06/04/2022.

Descomplicando Privacy by Design. Um guia prático para implementar os 7 princípios fundamentais na sua empresa. 2020. Disponível em:
<<https://content.inloco.com.br/hubfs/Privacidade%20-%20eBooks/Ebook-Descomplicando-PrivacyByDesign%2002.pdf?hsLang=pt-br>>. Acesso em: 06/04/2022.

ENGENHARIA DE PRIVACIDADE

Morales-Trujillo, M. E. et. al. **A Systematic Mapping Study of Privacy by Design in Software Engineering**. 2019. Disponível em:
<https://pdfs.semanticscholar.org/91f2/47c48e7a0d9b9fa65bfd2063bd99de06ca36.pdf?_ga=2.16583926.1168503056.1649266023-1704593130.1649266023>. Acesso em: 06/04/2022.

Hansen, M. et. al. **Protection Goals For Privacy Engineering**. 2015. Disponível em:
<<https://www.ieee-security.org/TC/SPW2015/IWPE/2.pdf>>. Acesso em: 06/04/2022.

Brooks, S. et. al. **NISTIR 8062. An Introduction to Privacy Engineering and Risk Management in Federal Systems.** National Institute of Standards and Technology (NIST), 2017. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/ir/2017/NIST.IR.8062.pdf>>. Acesso em: 06/04/2022.

Gurses, S. ; Troncoso, C. **Engineering Privacy by Design Reloaded.** Disponível em: <https://iapp.org/media/pdf/resource_center/Engineering-PbD-Reloaded.pdf>. Acesso em: 06/04/2022.

ESTRATÉGIAS DE PRIVACIDADE

Hoepman, J. **Privacy Design Strategies.** Radboud University Nijmegen, 2012. Disponível em: <<https://www.cs.ru.nl/~jhh/publications/pdp.pdf>>. Acesso em: 06/04/2022.

Hoepman, J. **Privacy Design Strategies (The Little Blue Book).** 2019. Disponível em: <<https://www.cs.ru.nl/~jhh/publications/pds-booklet.pdf>>. Acesso em: 06/04/2022.

Colesky, M.; Hoepman, J. **A Critical Analysis of Privacy Design Strategies.** 2016. Disponível em: <https://www.researchgate.net/profile/Michael-Colesky-2/publication/305870977_A_Critical_Analysis_of_Privacy_Design_Strategies/links/5a71f065a6fdcc53fe128104/A-Critical-Analysis-of-Privacy-Design-Strategies.pdf>. Acesso em: 06/04/2022.

Guía para el cumplimiento del deber de informar. Agencia Española de Protección de Datos Autoritat Catalana de Protecció de Dades; Agencia Vasca de Protección de Datos, 2017. Disponível em: <<https://www.aepd.es/media/guias/guia-modelo-clausula-informativa.pdf>>. Acesso em: 06/04/2022.

Machado, J. C. et al. **Estratégias para Proteção da Privacidade de Dados Armazenados na Nuvem.** Disponível em <<https://www.inf.ufpr.br/sbbd-sbsc2014/sbbd/proceedings/artigos/pdfs/14.pdf>>. Acesso em 05/04/2022.

IDENTIDADE FEDERADA

Identidade Federada. Disponível em: <https://stringfixer.com/pt/Federated_identity>. Acesso em: 06/04/2022.

Minicurso de Gerenciamento de Identidades Federadas. X Simpósio Brasileiro em Segurança da Informação e de Sistemas Computacionais, 2010. Disponível em: <<http://docente.ifsc.edu.br/mello/artigos/wangham-mc-sbseg10.pdf>>. Acesso em: 06/04/2022.

Manual de Gerenciamento de identidade federada utilizando vRealize Suite. VMware, 2019. Disponível em: <<https://docs.vmware.com/br/vRealize-Suite/2019/com.vmware.vrealizesuite.overview.doc/GUID-12B8635B-EF31-4D76-A391-1C626DF6D075.html>>. Acesso em: 06/04/2022.

Padrões de design na nuvem - Padrão de identidade federada. Microsoft, 2022. Disponível em: <<https://docs.microsoft.com/pt-br/azure/architecture/patterns/federated-identity>>. Acesso em: 06/04/2022.

K-ANONIMATO

Elaine Parra Affonso e Ricardo César Gonçalves Sant'Ana. **Preservação da Privacidade no**

Acesso a Dados por Meio do Modelo K-Anonimato. Disponível em:
<<https://periodicos.ufba.br/index.php/revistaici/article/view/13754/14661>>. Acesso em: 06/04/2022.

Javam Machado et. al. **Técnicas de Privacidade de Dados de Localização.** Disponível em:
<http://sbbd.org.br/2019/wp-content/uploads/sites/6/2019/10/Apresentacao_Minicurso_1_Privacidade.pdf>. Acesso em: 06/04/2022.

Spanish Data Protection Agency (AEPD) – Unit of Evaluation and Technological Studies. **Kanonymity as a privacy measure,** 06/2019. Disponível em:
<<https://www.aepd.es/media/notastecnicas/nota-tecnica-kanonimidad-en.pdf>>. Acesso em: 06/04/2022.

ARX – Data Anonymization Tool. Disponível em:
<<https://arx.deidentifier.org/overview/relatedsoftware/>>. Acesso em: 06/04/2022.

PADRÕES DE PRIVACIDADE

privacypatterns.eu - collecting patterns for better privacy. Disponível em:
<<https://privacypatterns.eu/>>. Acesso em: 06/04/2022.

Olha Drozd et. al. **Towards an Interactive Privacy Pattern Catalog.** 12th Symposium on Usable Privacy and Security (SOUPS 2016), 06/2016, Denver CO. Disponível em:
<https://www.researchgate.net/publication/305811615_Towards_an_Interactive_Privacy_Pattern_Catalog>. Acesso em: 06/04/2022.

Olha Drozd. **Privacy Pattern Catalog: A Tool for Integrating Privacy Principles of ISO/IEC 29100 into Software Development Process.** Disponível em:
<https://www.researchgate.net/publication/304995300_Privacy_Pattern_Catalogue_A_Tool_for_Integrating_Privacy_Principles_of_ISOIEC_29100_into_the_Software_Development_Process>.

Catalog – privacypatterns. Disponível em: <<http://privacypatterns.wu.ac.at:8080/catalog/>>. Acesso em: 06/04/2021.

Privacy patterns. Disponível em: <<https://privacypatterns.org/>>. Acesso em: 06/04/2021.

Technical Committee ISO/IEC JTC 1 /SC 27. **ISO/IEC 29100:2011 Information Technology - Security techniques – Privacy Framework.** Disponível em:<<https://www.iso.org/standard/45123.html>>.

TECNOLOGIAS DE AUMENTO DE PRIVACIDADE (TAPs)

Commission Of The European Communities. **Communication from the Commission to the European Parliament and the Council on Promoting Data Protection by Privacy Enhancing Technologies (PETs).** Disponível em: <<https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A52007DC0228>>. Acesso em: 06/04/2022.

The Technology Analysis Division of the Office of the Privacy Commissioner. **Privacy Enhancing Technologies – A review of Tools and Techniques.** 2017. Disponível em:

<https://www.priv.gc.ca/en/opc-actions-and-decisions/research/explore-privacy-research/2017/pet_201711/>. Acesso em:06/04/2022.

European Union Agency for Cybersecurity (ENISA). **Online privacy tools for the general public**.12/2015. Disponível em: <https://www.enisa.europa.eu/publications/privacy-tools-for-the-generalpublic/at_download/fullReport>. Acesso em: 06/04/2022.

European Union Agency for Cybersecurity (ENISA). **Readiness Analysis for the Adoption and Evolution of Privacy Enhancing Technologies**. 03/2016. Disponível em: <https://www.enisa.europa.eu/publications/pets/at_download/fullReport>. Acesso em 06/04/2022.

European Union Agency for Cybersecurity (ENISA). **PETs control matrix – A systematic approach for assessing online and mobile privacy tools**. Dec 2016. Disponível em: <<https://www.enisa.europa.eu/publications/pets-controls-matrix>>. Acesso em: 06/04/2022.

European Union Agency For Cybersecurity (ENISA). **Privacy Enhancing Technologies: Evolution and State of the Art**. 2017. Disponível em<<https://www.enisa.europa.eu/publications/pets-evolution-and-state-of-the-art>>. Acesso em:06/04/2022.

Ministry of Science, Technology and Innovation, Denmark. **Privacy Enhancing Technologies – META Group Report v1.1, Mar 2005**. Disponível em: <<https://danskprivacynet.files.wordpress.com/2008/07/rapportvedrprivacyenhancingtechnologies.pdf>>. Acesso em: 06/04/2022.

ISO

Technical Committee ISO/IEC JTC 1/SC 27. **ISO/IEC 29100:2011 Information technology – Security techniques – Privacy framework**. Disponível em <<https://www.iso.org/standard/45123.html>>. Acesso em 04/04/2022.

Technical Committee ISO/IEC JTC 1/SC 27. **ISO/IEC 29100:2011 Information technology – Security techniques – Privacy framework**. Disponível em: <https://standards.iso.org/ittf/PubliclyAvailableStandards/c045123_ISO_IEC_29100_2011.zip>. Acesso em 04/04/2022.

Technical Committee ISO/IEC JTC 1/SC 27. **ISO/IEC 27701:2019 Security techniques – Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management – Requirements and guidelines**. Disponível em: <<https://www.iso.org/standard/71670.html>>. Acesso em: 04/2022.

ABNT NBR ISO/IEC 27002:2013 - Tecnologia da informação — Técnicas de segurança — Código de prática para controles de segurança da informação. Disponível em: <<https://www.abntcatalogo.com.br/norma.aspx?Q=Q0l4Qy9lSjZqVnpSR1BaTU8wZ0JsSsvdmY3S2ZNUWJEbHNWWH3ak1UUTO=>>>.

ABNT NBR ISO/IEC 27002:2013 - Tecnologia da informação — Técnicas de segurança — Código de prática para controles de segurança da informação. Disponível em:

<https://pt.wikipedia.org/wiki/ISO/IEC_27002>.

LEI GERAL DE PROTEÇÃO DE DADOS – LGPD

Comitê Central de Governança de Dados - CCGD. **Guia de Boas Práticas LGPD**. Disponível em: <<https://www.gov.br/governodigital/pt-br/governanca-de-dados/guia-de-boas-praticas-lei-geral-de-protecao-de-dados-lgpd>>. Acesso em: 06/04/2022.

Governo Digital. **Guias operacionais para adequação à LGPD**. Disponível em: <<https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/guias-operacionais-paraadequacao-a-lei-geral-de-protecao-de-dados-pessoais-lgpd>>. Acesso em: 06/04/2022.

Brasil. **Lei Geral de Proteção de Dados Pessoais (LGPD)**. In: Diário Oficial [da] República Federativa do Brasil, Brasília, 28 dez. 2018b. BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Diário Oficial [da] República Federativa do Brasil, Brasília, 15 ago. 2018a. Disponível em: <http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm>. Acesso em: 07/11/2020.

MPF. **O que é a LGPD?**. Disponível em: <<https://www.mpf.mp.br/servicos/lgpd/o-que-e-a-lgpd>>.

Gustavo Fonseca Goncalves de Almeida

Assessor Chefe de Tecnologia da Informação e Comunicação

Paulo Henrique Correa de Moura

Secretário Adjunto de Tecnologia da Informação e Comunicação

Darlan Airton Dias

Secretário de Tecnologia da Informação e Comunicação



MINISTÉRIO PÚBLICO FEDERAL

Assinatura/Certificação do documento **PGR-00514378/2022 DOCUMENTO DIVERSO**

.....
Signatário(a): **PAULO HENRIQUE CORREA DE MOURA**

Data e Hora: **09/12/2022 11:37:10**

Assinado com login e senha

.....
Signatário(a): **DARLAN AIRTON DIAS**

Data e Hora: **09/12/2022 16:35:55**

Assinado com login e senha

.....
Signatário(a): **GUSTAVO FONSECA GONCALVES DE ALMEIDA**

Data e Hora: **12/12/2022 11:20:16**

Assinado com login e senha

.....
Acesse <http://www.transparencia.mpf.mp.br/validacaodocumento>. Chave 68060940.8daa220c.70023481.e7b60be1